Firewall Placement, Zones, and Access Control Lists

IE3122: Network Security | Week 7

Where firewalls actually go in a network, and how to configure what passes through them

Today's Agenda

- What a DMZ is, and why it exists
- Zone-Based Firewall as a configuration model, not a new technology
- Four firewall placement architectures, compared for strengths and weaknesses
- Access Control Lists: Standard, Extended, and Named
- ACL placement rules, and a worked configuration example

Learning Outcomes for Today

LO3

– Analyse security requirements and recommend appropriate technologies.

LO4

– Evaluate different security technologies, compare them, and identify appropriate use cases.

LO5

– Configure security technologies to satisfy specific requirements.

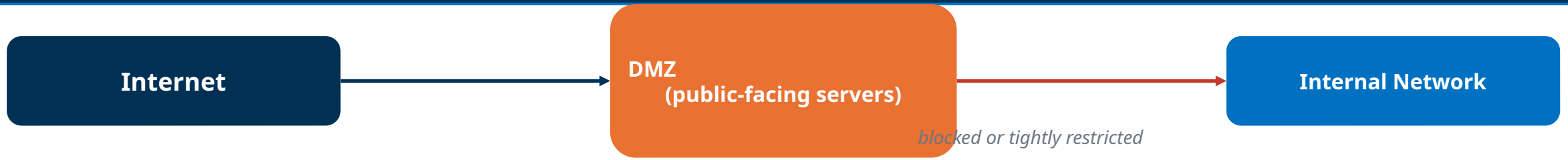
– *By the end of this session you should be able to recommend a placement architecture for a given scenario, and correctly configure and place an ACL to enforce it.*

The DMZ and the Zone-Based Model

A buffer network, and a way of thinking about policy

CONCEPT

What Is a DMZ?



- A DMZ (Demilitarised Zone) is a buffer network segment sitting between a trusted internal network and an untrusted external one, usually the Internet.
- It hosts services that genuinely need to be reachable from outside, such as web, email, or DNS servers, without exposing the internal network directly to that same exposure.
- The key principle: if a DMZ-hosted server is compromised, the attacker still doesn't have a direct path into the internal network. The DMZ contains the damage rather than preventing it entirely.

Zone-Based Firewall: A Configuration Model, Not a New Technology

- Recall Deck A's seven types: those are inspection technologies, answering the question of how a decision gets made.
- Zone-Based Firewall (ZBF) answers a different question entirely: how do you organize policy across many interfaces as a network grows? Any of the seven types could sit underneath a ZBF configuration.
- Interfaces are assigned to logical zones, such as INSIDE, OUTSIDE, and DMZ, rather than writing policy per individual interface pair.
- Traffic is only permitted between two different zones if an explicit zone-pair policy allows it. By default, traffic between different zones is denied unless stated, while traffic within the same zone is typically allowed by default.
- A zone-pair policy is directional and doesn't have to be symmetric: an INSIDE-to-OUTSIDE policy can be broad, while the OUTSIDE-to-INSIDE policy for the same two zones can be far stricter.

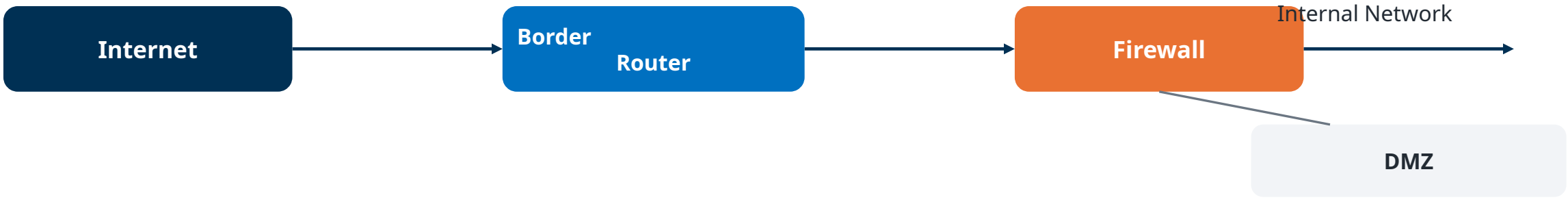
How DMZ and ZBF Fit Together

- The DMZ concept from the previous slide maps directly onto ZBF: a three-zone design (INSIDE, OUTSIDE, DMZ) is one of the most common real-world ZBF configurations.
- Each zone-pair gets its own tailored policy: OUTSIDE-to-DMZ permits specific public services; DMZ-to-INSIDE is denied or extremely restricted; INSIDE-to-OUTSIDE and INSIDE-to-DMZ are generally permitted.
- The advantage over configuring ACLs per interface directly: as the network grows, you reason about policy in terms of which zones may talk to which, not by tracking every individual interface pairing by hand. This scales far better and is much easier to audit.

Four Placement Architectures

Where the firewall (or firewalls) actually sit relative to the border router

Architecture 1: Single Firewall Behind the Border Router



Strengths

- Simple, single point of policy management
- Lower cost, only one security device to buy and maintain

Weaknesses

- Single point of failure for the whole network
- DMZ and internal traffic compete for the same device's rules and processing

Architecture 2: Single Firewall In Front of the Border Router



Strengths

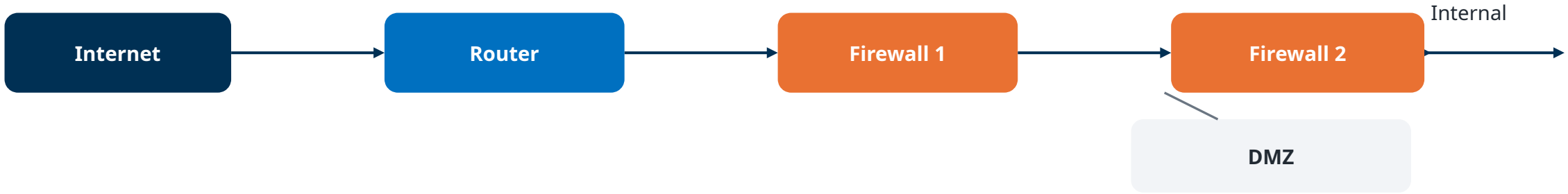
- The firewall inspects and filters all traffic before it even reaches the router, protecting the router itself
- Simpler conceptual flow for a small network where the firewall doubles as the primary gateway

Weaknesses

- Non-standard design, so less documented best practice and vendor guidance
- The router's own management and routing-protocol traffic must all pass through firewall policy, adding complexity

PLACEMENT

Architecture 3: Dual Firewall, Router Before Both (Screened Subnet)



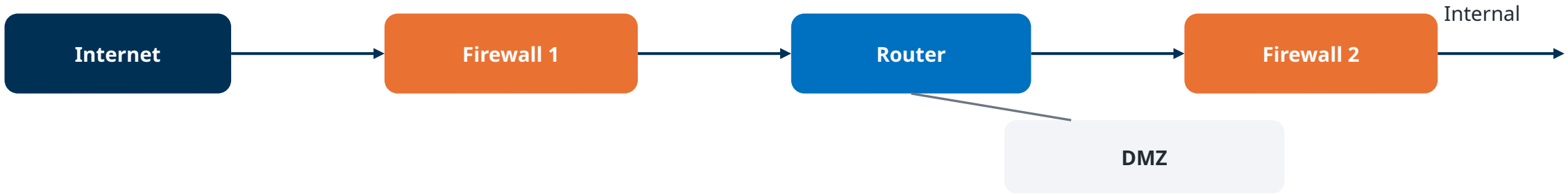
Strengths

- Strong defence in depth: an attacker must compromise two separate firewalls to reach the internal network
- The DMZ is genuinely isolated between two distinct security boundaries
- Each firewall's policy can be tailored specifically to its position

Weaknesses

- Higher cost, two firewall devices to buy, license, and maintain
- More complex configuration and management overhead
- Real risk of policy inconsistency between the two devices if not carefully coordinated

Architecture 4: Dual Firewall, Router Between the Two



Strengths

- Firewall 1 filters all inbound internet traffic before it even reaches the router, protecting the router directly
- The router can focus purely on routing and NAT for the DMZ segment, without also being a security boundary

Weaknesses

- If Firewall 1 is bypassed, the router sits exposed with no second firewall immediately in front of it
- Less common, less standardised design pattern with less vendor documentation
- The router becomes a dependency sitting between two security devices, a potential chokepoint

SUMMARY

Architecture Comparison

Architecture	Firewalls	Router Position	Key Trade-off
Single, Behind Router	1	Before the firewall	Simple and cheap, but a single point of failure
Single, In Front of Router	1	After the firewall	Protects the router, but non-standard
Dual, Router Before Both	2	Before both firewalls	Strong defence in depth, higher cost and complexity
Dual, Router Between	2	Between the two firewalls	Protects the router directly, but the router itself is exposed if Firewall 1 is bypassed

Access Control Lists

The hands-on configuration you'll use in this week's lab

ACL Fundamentals

- An ACL is an ordered list of permit and deny statements applied to an interface. Statements are evaluated strictly top to bottom.
- The first statement that matches a given packet wins, and processing stops there. Statements further down the list are never even checked for that packet.
- Every ACL ends with an implicit deny, even though it's invisible in the configuration. If no statement matches, the traffic is dropped by default.
- An ACL is applied per interface and per direction, inbound or outbound, so the same list can behave completely differently depending on where and which way you apply it.

Standard ACLs

- Filters based only on source IP address. Nothing else about the packet is considered, not the destination, not the protocol, not the port.
- Numbered in the ranges 1 to 99 and 1300 to 1999.
- Because a Standard ACL can't distinguish by destination, applying it too early in the network risks blocking traffic to destinations you never intended to affect.
- Best practice, covered in detail shortly: place a Standard ACL as close to the destination as possible.

Extended ACLs

- Filters based on source and destination IP address, the protocol (TCP, UDP, ICMP, and others), and source and destination port numbers.
- Numbered in the ranges 100 to 199 and 2000 to 2699.
- Because an Extended ACL can match precisely on both source and destination together, it can safely be applied much earlier without the same risk of over-blocking that a Standard ACL carries.
- Best practice, covered in detail shortly: place an Extended ACL as close to the source as possible.

Named ACLs

- Functionally identical to a Standard or Extended ACL. The only difference is that a Named ACL is identified by a descriptive name instead of a number.
- A single Named ACL is still either standard-style or extended-style underneath. Naming it doesn't add new matching capability.
- The practical advantage is readability and maintainability: a name like BLOCK_TELNET_FROM_GUEST documents its own purpose, and individual lines can be added or removed without recreating the whole list.

Standard ACL: Command Format in Detail

```
access-list {1-99 | 1300-1999} {permit | deny} {source} [source-wildcard] [log]
```

- Number: 1 to 99, or the expanded range 1300 to 1999. This is what tells the router the list is a Standard ACL.
- permit or deny: the action taken when a packet matches this line.
- Source: the address to match. This can be a specific host, a network combined with a wildcard mask, or the keyword any to match every address.
- Source wildcard: the inverse of a subnet mask, marking which bits must match exactly (0) and which can be anything (1). The keyword host is shorthand for a wildcard of 0.0.0.0, an exact single-address match.
- log (optional): records a message whenever this line is matched, useful for monitoring without changing the action taken.

```
Example: access-list 10 permit 192.168.100.0 0.0.0.31
Example: access-list 10 permit host 192.168.100.5
```

- Applied to an interface the same way as any ACL: interface GigabitEthernet0/0, then ip access-group 10 out.

Extended ACL: Command Format in Detail

```
access-list {100-199 | 2000-2699} {permit | deny} {protocol}
  {source} [source-wildcard] [operator port]
  {destination} [destination-wildcard] [operator port] [established] [log]
```

- Number: 100 to 199, or the expanded range 2000 to 2699, identifying this as an Extended ACL.
- Protocol: ip for all traffic, or a specific protocol such as tcp, udp, or icmp. Port matching only applies when the protocol is tcp or udp.
- Source and destination: each specified the same way as a Standard ACL, host, network plus wildcard, or any, but here both ends of the conversation are matched, not just the source.
- Operator port: an optional comparison (eq, gt, lt, neq, or range) followed by a port number or name, applied separately to source and destination.
- established (TCP only, optional): matches only packets that are part of an already-established session, meaning the ACK or RST flag is set. This directly reflects Week 6's TCP handshake: a fresh SYN with no ACK will not match this keyword.

```
Example: access-list 101 deny tcp 192.168.10.0 0.0.0.255 host 192.168.20.5 eq 23
```

Named ACL: Command Format in Detail

```
ip access-list {standard | extended} {name}
  [sequence-number] {permit | deny} { ...rest is identical to the matching
     Standard or Extended syntax above, just without repeating the name... }
```

- The first line enters a dedicated configuration sub-mode for that one list, rather than repeating access-list and a number on every line.
- Inside that sub-mode, every subsequent line is just permit or deny, matched exactly like the Standard or Extended syntax already covered, since a Named ACL is either type underneath, never a third kind of matching logic.
- An optional sequence number at the start of a line (for example 10, 20, 30) lets you insert a new line at a specific position later, without deleting and retyping the whole list.
- The name itself must start with a letter, cannot contain spaces, is case-sensitive, and must be unique among all ACLs of that same type.

```
Example: ip access-list extended BLOCK_TELNET_TO_SERVER
  10 deny tcp 192.168.10.0 0.0.0.255 host 192.168.20.5 eq 23
  20 permit ip any any
```

ACL Placement Rules

- Standard ACL: place it close to the destination. Since it can only filter by source address, placing it near the destination avoids accidentally blocking that source's traffic to other, unintended destinations elsewhere in the network.
- Extended ACL: place it close to the source. Since it can already match precisely on destination, protocol, and port, there's no benefit to letting unwanted traffic travel further into the network first. Stop it as early as possible instead.
- This connects directly back to the placement architectures you just saw: deciding where a firewall or router sits in the topology, and deciding where within that device's interfaces to apply a specific ACL, are both the same underlying question. Match traffic as early and as precisely as the tool allows, without over-blocking.

Worked Example: Extended ACL

- Scenario: block Telnet (port 23) from the 192.168.10.0/24 subnet to a specific server at 192.168.20.5, while permitting everything else.

```
access-list 101 deny tcp 192.168.10.0 0.0.0.255 host 192.168.20.5 eq 23
access-list 101 permit ip any any
interface GigabitEthernet0/1
 ip access-group 101 in
```

- Applied close to the source (the 192.168.10.0/24 subnet's own gateway interface), exactly matching the Extended ACL placement rule from the previous slide.
- The explicit permit ip any any at the end matters. Without it, the ACL's implicit deny would silently block every other kind of traffic too, not just Telnet.

Worked Example: Named ACL (Same Policy, Named Style)

```
ip access-list extended BLOCK_TELNET_TO_SERVER
 deny tcp 192.168.10.0 0.0.0.255 host 192.168.20.5 eq 23
 permit ip any any
interface GigabitEthernet0/1
 ip access-group BLOCK_TELNET_TO_SERVER in
```

- Identical behaviour to the numbered version on the previous slide. The only difference is the self-documenting name in place of the number 101.
- In modern IOS, a specific line inside this named list can be removed or a new one inserted at a specific sequence number, without deleting and rebuilding the entire list.

ACL Summary

ACL Type	Filters On	Number Range	Best Placement
Standard	Source IP address only	1-99, 1300-1999	Close to the destination
Extended	Source/destination IP, protocol, port	100-199, 2000-2699	Close to the source
Named	Same as Standard or Extended underneath	N/A, identified by name	Same as its underlying type

Summary

- A DMZ exists to contain damage: if a public-facing server is compromised, the internal network still isn't directly reachable from there.
- Zone-Based Firewall is a way of organising policy, not a new inspection technology. Any firewall type from Deck A can sit underneath a ZBF configuration.
- All four placement architectures trade the same two things against each other: cost and management complexity versus depth of defence, whether that's one firewall or two, or where exactly the router sits relative to them.
- Standard ACLs filter on source address alone and belong close to the destination. Extended ACLs can match precisely and belong close to the source. Named ACLs are either of those, just easier to read and maintain.

This Week's Lab & Tutorial

- Lab: hands-on Standard, Extended, and Named ACL configuration in Packet Tracer, including verifying placement and confirming the implicit deny behaves as expected.
- Tutorial worksheet: study-notes-style questions covering the DMZ, Zone-Based Firewall, the four placement architectures, and ACL configuration and placement. Use it to prep for the mid-semester test.

References

- Santos & Stuppi, CCNA Security 210-260 Official Cert Guide, 1st Ed., Cisco Press.
- Kaufman, Perlman, Speciner & Perlner, Network Security: Private Communication in a Public World, 3rd Ed., Prentice Hall.
- Cisco Networking Academy, CCNA Security curriculum (Firewall placement and ACL chapters).